

Inconsistent CORS Matching Due to Handling of "+" in URL Path in [corydolphin/flask-cors](#)

✓ Valid

Reported on May 12th 2024

Description

The Flask CORS extension has a bug where the request.path is passed through the unquote_plus function, which converts the `+` character to a space . Since `+` is a valid character in URL paths, this behavior leads to incorrect path normalization, causing potential mismatches in CORS configuration. This can result in endpoints not being matched correctly to their CORS settings, leading to unexpected CORS policy application.

Proof of Concept

```
from flask import Flask, jsonify
import logging
try:
    from flask_cors import CORS # The typical way to import flask-cors
except ImportError:
    # Path hack allows examples to be run without installation.
    import os
    parentdir = os.path.dirname(os.path.dirname(os.path.abspath(__file__)))
    os.sys.path.insert(0, parentdir)

    from flask_cors import CORS

app = Flask('FlaskCorsAppBasedExample')
logging.basicConfig(level=logging.INFO)

# To enable logging for flask-cors,
logging.getLogger('flask_cors').level = logging.DEBUG

CORS(app, resources={
    r'/api/*': {'origins': ['*']},
    r'/api/super\+Secret': {'origins': ['https://onlythis.com']}
})

@app.route("/api/super+Secret")
def secret():
    return "Very Confidential. Only serve to https://onlythis.com"

@app.route("/api/v1/users/")
```

```
def list_users():  
    return jsonify(user="joe")  
  
if __name__ == "__main__":  
    app.run(debug=True)
```

Request:

```
GET /api/super+Secret HTTP/1.1  
Host: 127.0.0.1:5000  
Origin: https://evil.com  
Connection: close
```

Response:

```
HTTP/1.0 200 OK  
Content-Type: text/html; charset=utf-8  
Content-Length: 53  
Access-Control-Allow-Origin: https://evil.com  
Vary: Origin  
Server: Werkzeug/1.0.1 Python/3.9.5  
Date: Sat, 11 May 2024 20:10:28 GMT  
  
Very Confidential. Only serve to https://onlythis.com
```

Impact

The incorrect conversion of `+` to a space in URL paths can cause legitimate requests to miss their intended CORS policies, potentially allowing unauthorized cross-origin access or blocking valid requests. This misconfiguration creates security vulnerabilities and usability issues, making it difficult for developers to apply precise CORS rules.

Occurrences

 extension.py L193

References

- [rfc 3986 - sub-delims \(including "+"\) is allowed as a path character](#)

 We are processing your report and will contact the [corydolphin/flask-cors](#) team within 24 hours. 2 years ago

 A [GitHub Issue](#) asking the maintainers to create a `SECURITY.md` exists 2 years ago



huntr-helper modified the Severity from High (8.3) to Medium (6.5) 2 years ago

We were unable to make contact with the **corydolphin/flask-cors** team automatically, our community manager will try to reach out to them instead. 2 years ago

We have sent a magic link to the **corydolphin/flask-cors** team via the email provided in their **security policy** 2 years ago

We have sent a follow up to the **corydolphin/flask-cors** team. We will try again in 4 days. 2 years ago

We have sent a second follow up to the **corydolphin/flask-cors** team. We will try again in 7 days. 2 years ago

We have sent a third follow up to the **corydolphin/flask-cors** team. We will try again in 14 days. 2 years ago

We have sent a fourth follow up to the **corydolphin/flask-cors** team. We will send a final notification 48 hours before report publication. 2 years ago



tomorrowisnew_ commented 2 years ago

Researcher

How long @admin



Marcello modified the Severity from Medium (6.5) to Medium (5.3) 2 years ago

The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Marcello validated this vulnerability 2 years ago

Validating as maintainer was contacted with no response.

tomorroisnew has been awarded the disclosure bounty

The fix bounty is now up for grabs

The researcher's credibility has increased: +7



CVE-2024-6844 assigned to this report. 2 years ago

We have sent a warning to the **corydolphin/flask-cors** team to inform them that this report will be published in 48 hours a year ago



This vulnerability has now been published a year ago



[Sign in](#) to join this conversation

CVE
CVE-2024-6844
Published

Vulnerability Type
CWE-346: Origin Validation Error

Severity
Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	Low
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry
Pypi

Affected Version
4.0.1

Visibility
Public

Status
Awaiting fix

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



tomorrowisnew_
@tomorroisnew
MIDDLEWEIGHT



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)